

CCS6224

Network Security

Lecture 8
Network Access Control (NAC)
Cloud Security

Outline

- › NAC
- › EAP
- › EAP over LAN (EAPOL)
- › 802.1X
- › Cloud Security

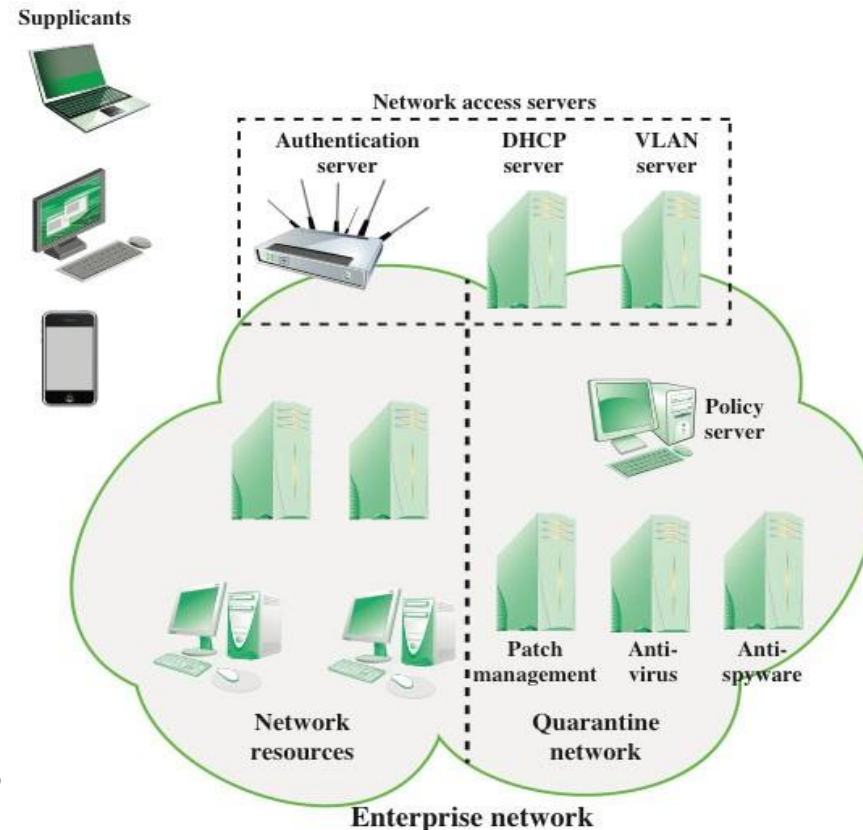
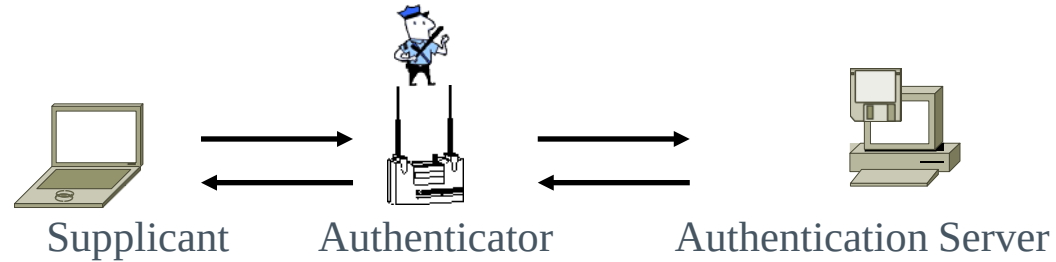
Network Access Control (NAC)

□ AAA:

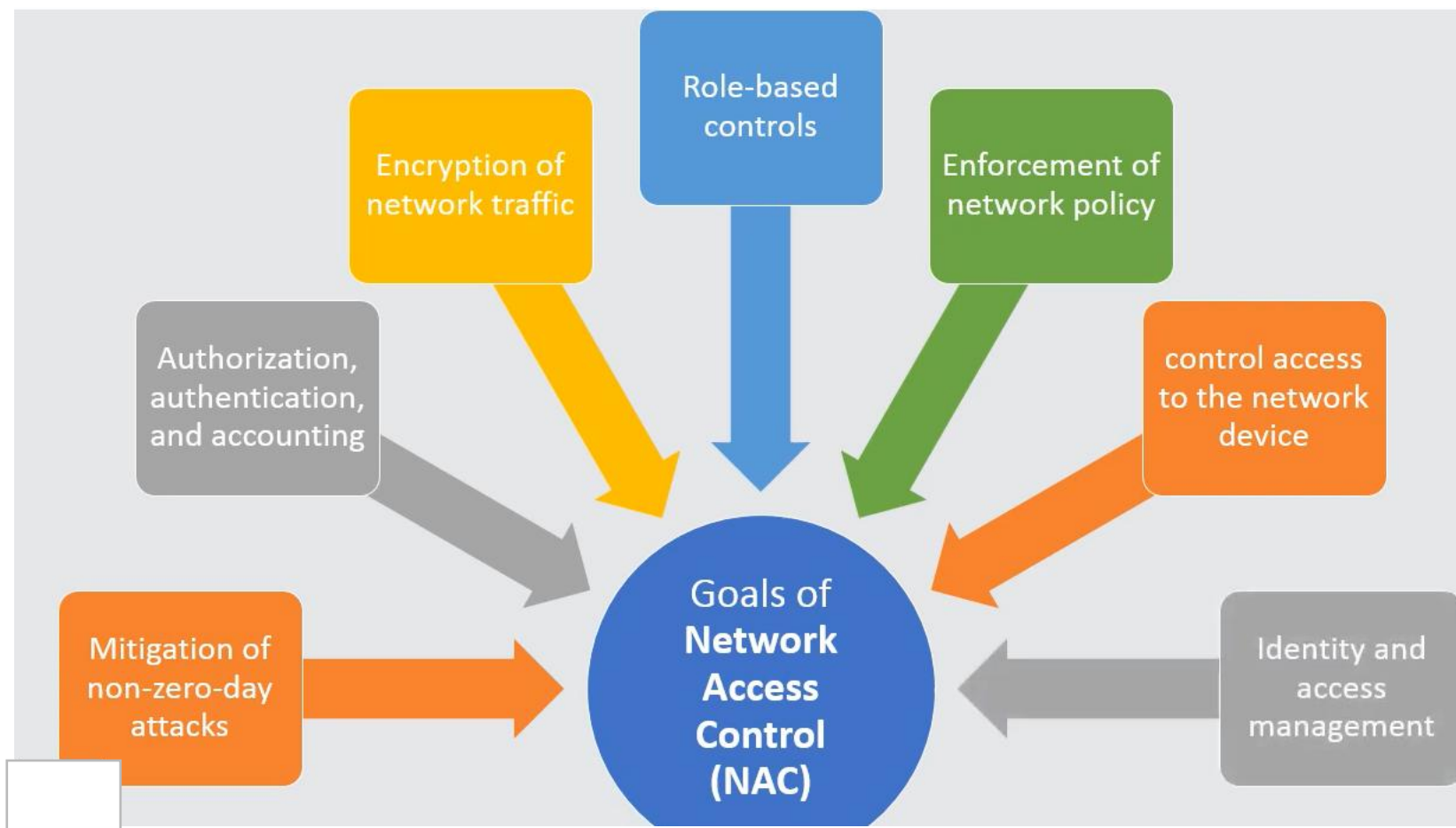
- **Authentication:**
Is user legit?
- **Authorization:**
What is he allowed to do?
- **Accounting:**
Keep track of usage

□ Components:

- **Supplicant:** User
- **Authenticator:**
Network edge device
- **Authentication Server:**
Remote Access Server (RAS) or Policy Server
Backend policy and access control



Goal of NAC



Elements of a Network Access Control System

NAC systems deal with three categories of components:

Access requester (AR)

- Node that is attempting to access the network and may be any device that is managed by the NAC system, including workstations, servers, printers, cameras, and other IP-enabled devices
- Also referred to as *supplicants*, or clients

Policy server

- Determines what access should be granted
- Often relies on backend systems

Network access server (NAS)

- Functions as an access control point for users in remote locations connecting to an enterprise's internal network
- Also called a *media gateway*, *remote access server (RAS)*, or *policy server*
- May include its own authentication services or rely on a separate authentication service from the policy server

Suplicants



Network access servers

**Authentication
server**



**DHCP
server**



**VLAN
server**



**Network
resources**



**Policy
server**



**Patch
management**



**Anti-
virus**



**Anti-
spyware**

**Quarantine
network**

Enterprise network

Figure 16.1 Network Access Control Context



Network Access Enforcement Methods

- › The actions that are applied to ARs to regulate access to the enterprise network
 - Many vendors support multiple enforcement methods simultaneously, allowing the customer to tailor the configuration by using one or a combination of methods

Common NAC enforcement methods:

- IEEE 802.1X
- Firewall
- DHCP management
- VPN
- VLANs

EAP

- › Old Methods: Password Authentication Protocol (PAP), Challenge Handshake Authentication Protocol (CHAP), Microsoft CHAP (MS-CHAP)
- › EAP provides a generic transport service for the exchange of authentication information between a client system and an authentication server
- › The basic EAP transport service is extended by using a specific authentication protocol that is installed in both the EAP client and the authentication server

Commonly supported EAP methods:

- EAP Transport Layer Security
- EAP Tunneled TLS
- EAP Generalized Pre-Shared Key
- EAP-IKEv2

Extensible Authentication Protocol

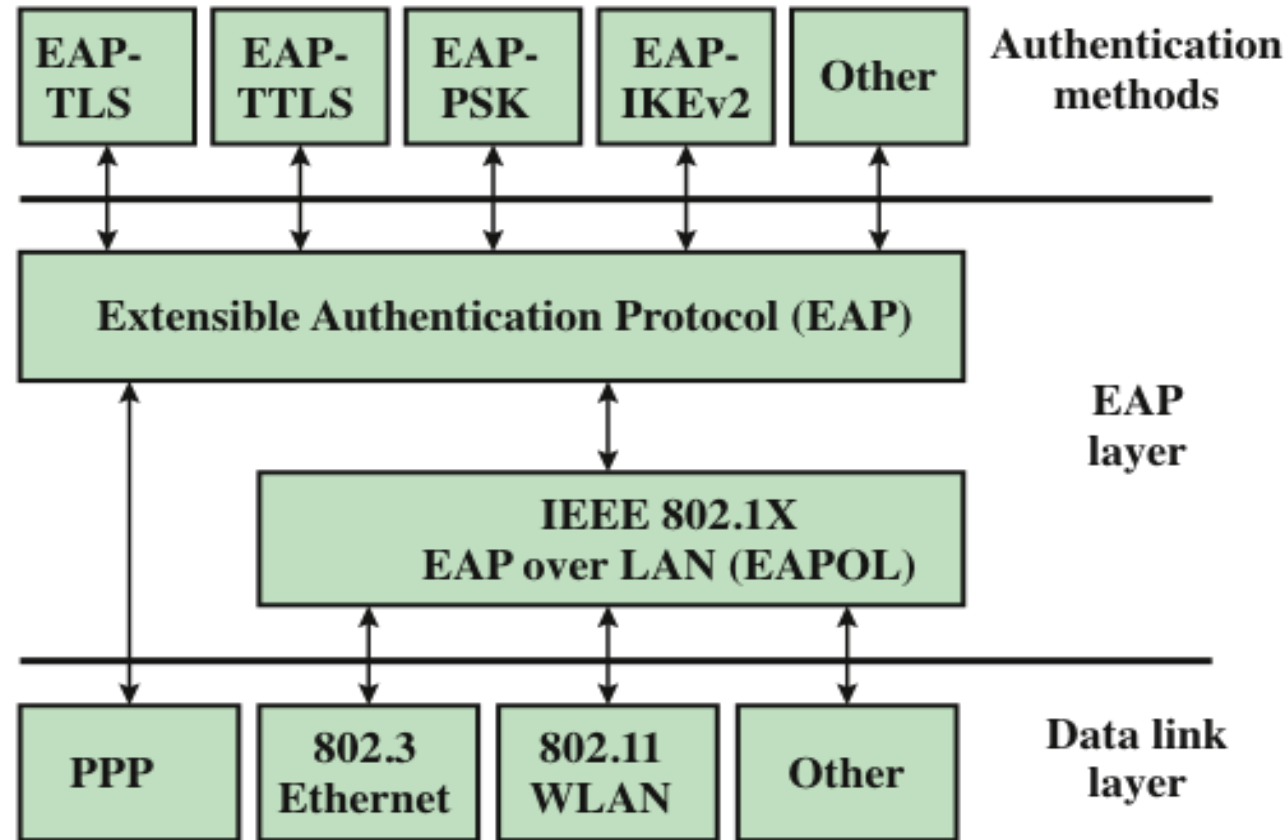
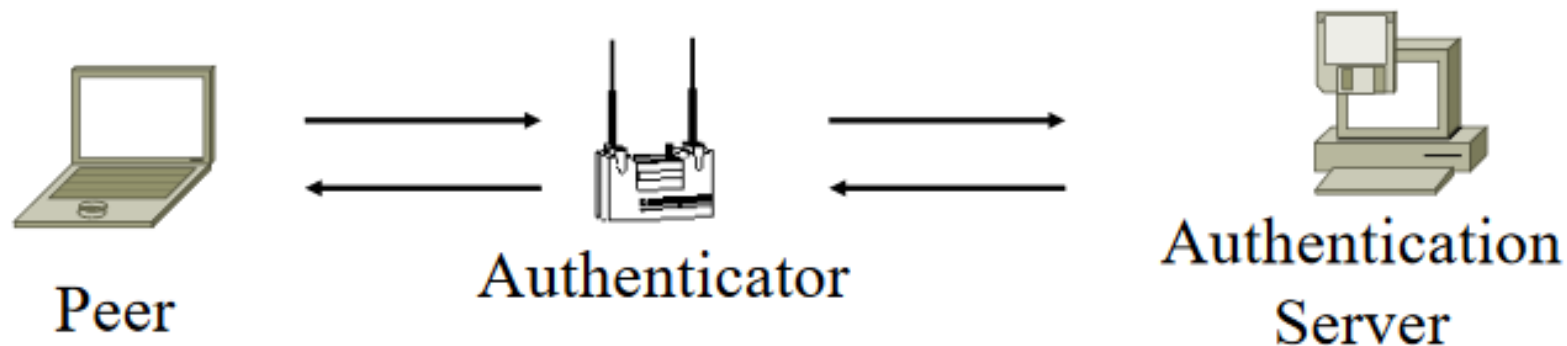


Figure 16.2 EAP Layered Context

EAP Terminology

- › Peer: Entity to be authenticated = Supplicant/ User
- › Authenticator: Authenticating entity
- › Authentication Server: Has authentication database
- › If there is NO backend AS, then EAP Server = Authenticator
- › Master Session Key (MSK) is the keying material agreed by the peer and the EAP server, at least 64bits. Commonly given by the server to authenticator



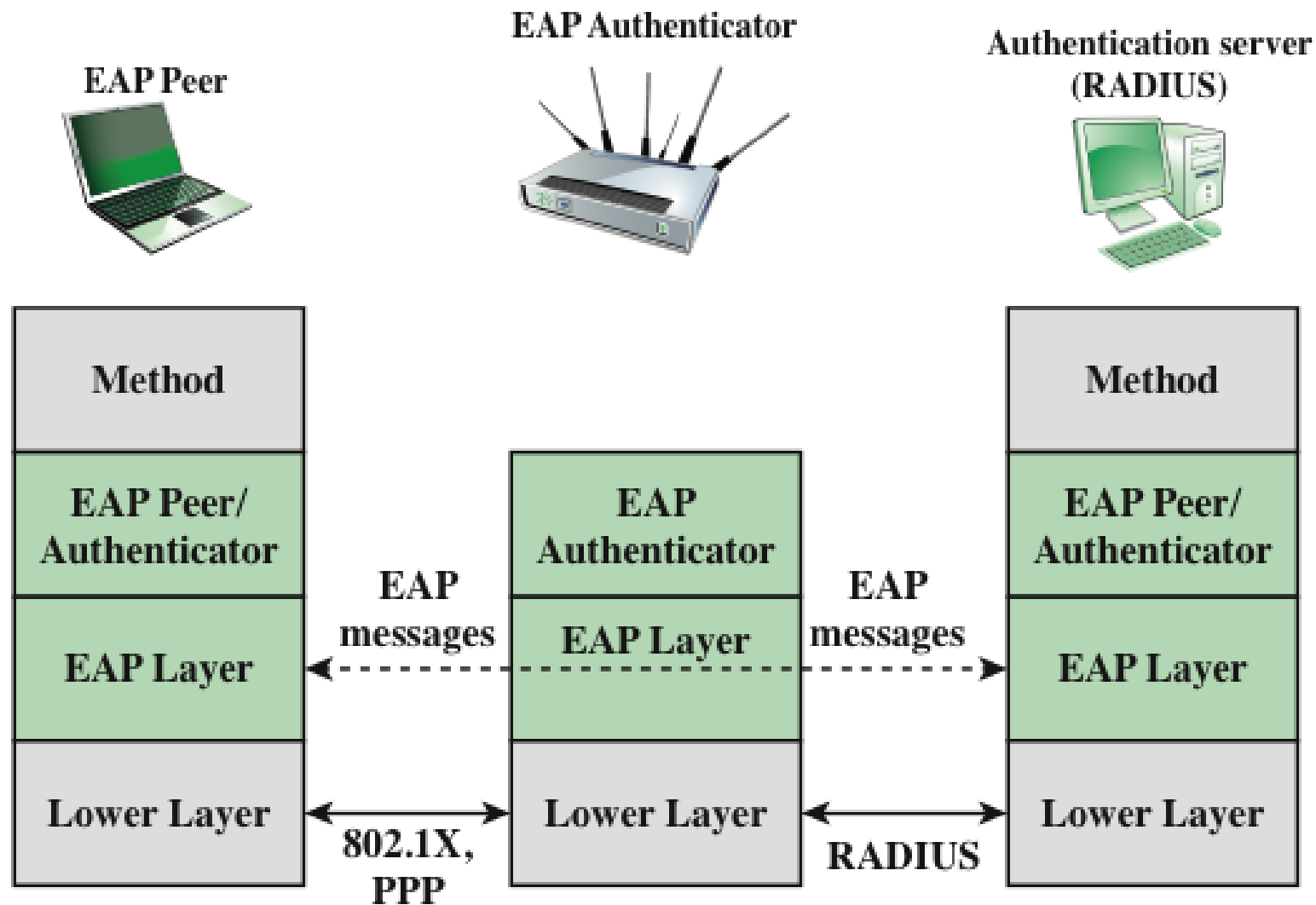
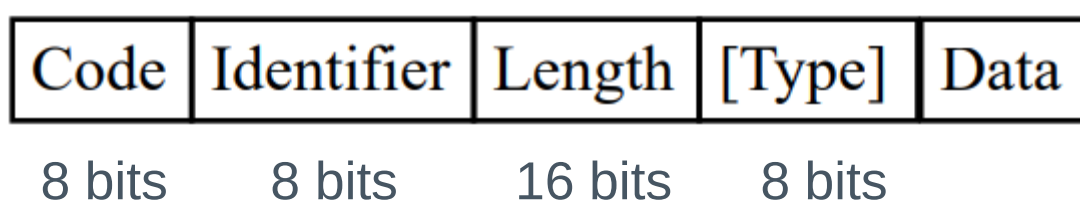


Figure 16.3 EAP Protocol Exchanges

EAP Exchange

- › EAP message format:



- › Only 4 message codes:

1 = Request
2 = Response
3 = Success
4 = Failure

- › Identifier is incremented for each message. Identifier in response is the same with that in request
- › Type/field indicates the authentication assigned by IANA

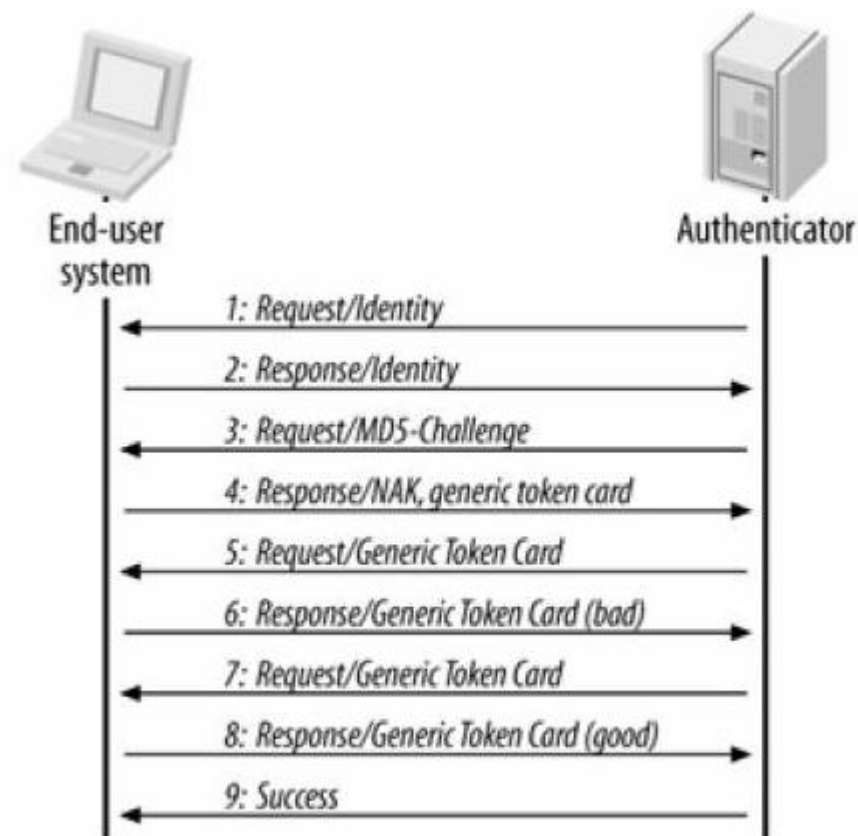
EAP Message Examples

```
+ Frame 72: 60 bytes on wire (480 bits), 60 bytes captured
+ Radiotap Header v0, Length 18
+ IEEE 802.11 QoS Data, Flags: .....F.
+ Logical-Link Control
- 802.1X Authentication
  Version: 802.1X-2004 (2)
  Type: EAP Packet (0)
  Length: 4
- Extensible Authentication Protocol
  Code: Success (3)
  Id: 222
  Length: 4
```

```
+ Frame 283: 64 bytes on wire (512 bits), 64 bytes captured (512 bits)
+ Ethernet II, Src: aa:bb:cc:00:01:30 (aa:bb:cc:00:01:30), Dst: 01:80:c
- 802.1X Authentication
  Version: 802.1X-2004 (2)
  Type: EAP Packet (0)
  Length: 4
- Extensible Authentication Protocol
  Code: Failure (4)
  Id: 35
  Length: 4
```

EAP Types

- › 1 = Identity
- › 2 = Notification (messages to be displayed to user)
- › 3 = Nack
- › 4 = MD5 Challenge (CHAP)
- › 5 = One time password
- › 6 = Generic Token card (GTC)
- › ... 255 = Experimental



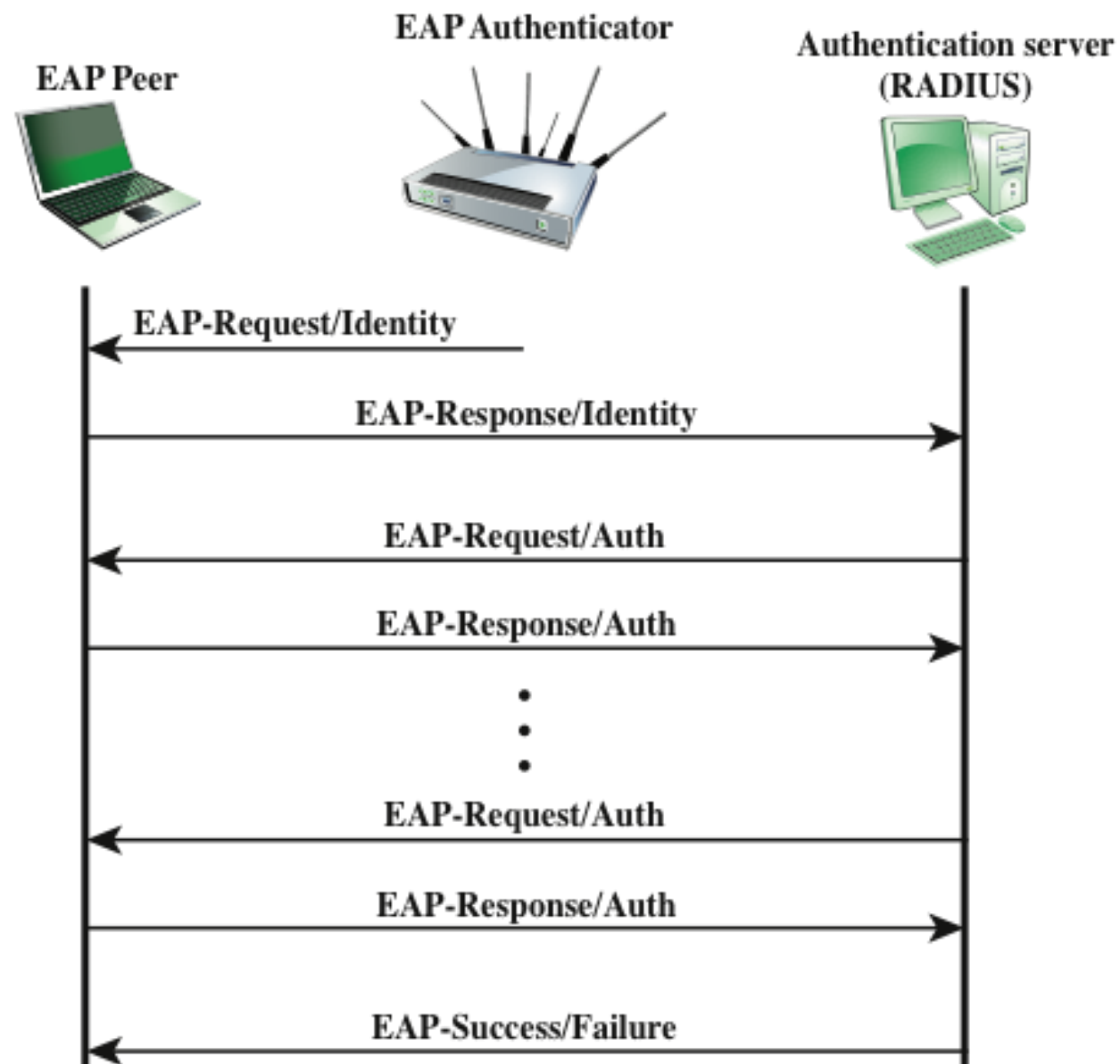
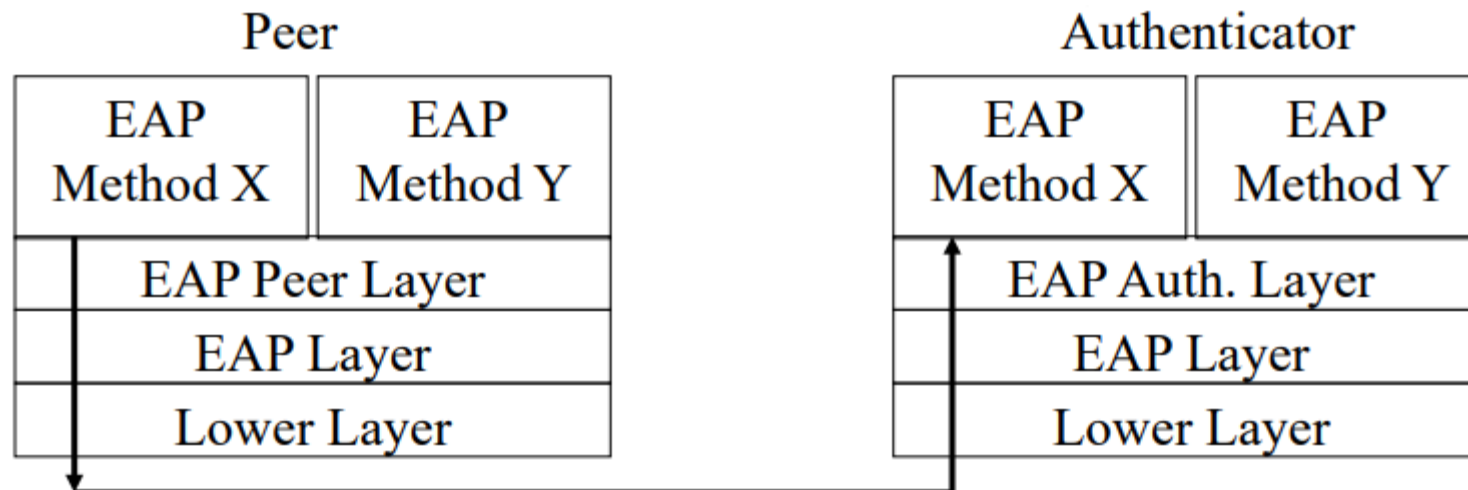


Figure 16.4 EAP Message Flow in Pass-Through Mode

EAP Multiplexing Model

- › EAP Layer demultiplexes using code. Code 1 (request), 3 (success), and 4 (failure) are delivered to the peer layer
- › Code 2 (response) is delivered to the EAP authenticator layer
- › Both ends may need to implement peer layer and authenticator layer for mutual authentication





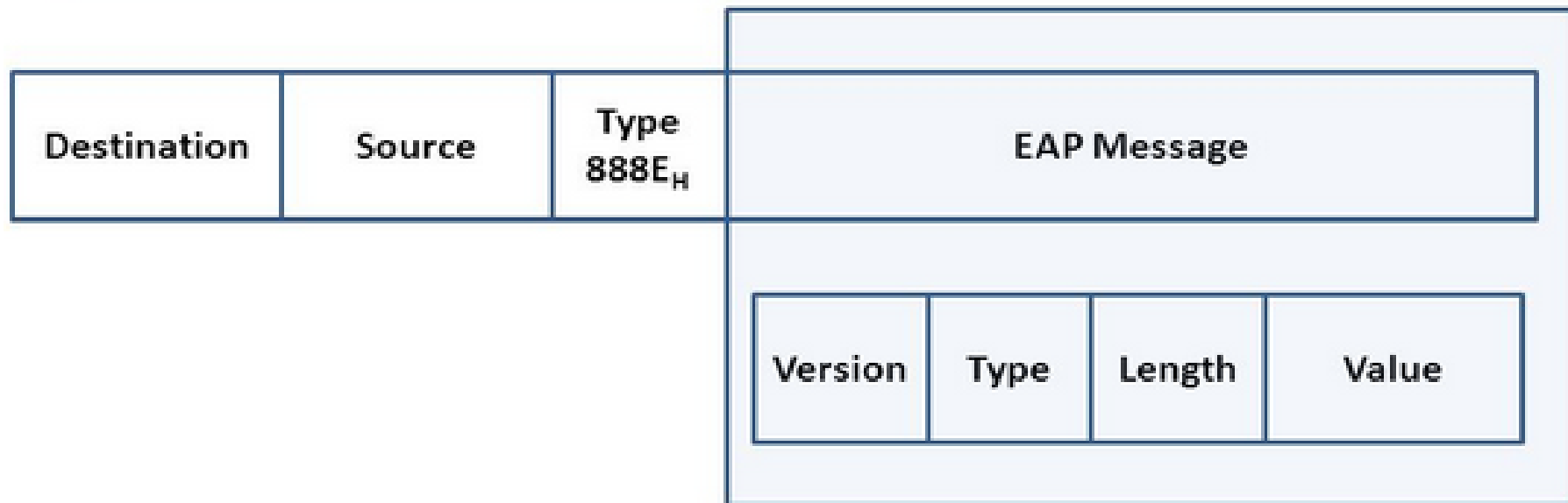
EAP Upper Layer Protocols

- › **EAP-TLS**: Transport Level Security. Both sides need certificates
- › **EAP-TTLS**: Tunneled TLS. Only server certificates. Secure tunnel for peer
- › **EAP-PSK**: Pre-shared key+AES-128 to generate keys
- › **EAP-IKEv2**: Internet Key Exchange. Mutual authentication. Certificate, Password, or Shared secret
- › **EAP-FAST**: Flexible Authentication via Secure Tunneling. Certificates optional. Protected tunnels
- › **Protected EAP (PEAP)**: Server Certificates. Client password
- › **PEAPv1 or EAP-GTC**: Generic Token Cards. Client uses secure tokens

EAP over LAN (EAPOL)

- › EAP was designed for Point-to-point line. IEEE extended it for LANs $\Rightarrow$ EAPOL
- › Added a few more messages and fields
- › Five types of EAPOL messages:
 1. EAPOL Start: Sent to a multicast address
 2. EAPOL Key: Contains encryption and other keys sent by the authenticator to supplicant
 3. EAPOL packet: Contains EAP message (Request, Response, Success, Failure)
 4. EAPOL Logoff: Disconnect
 5. EAPOL Encapsulated-ASF-Alert: Management alert

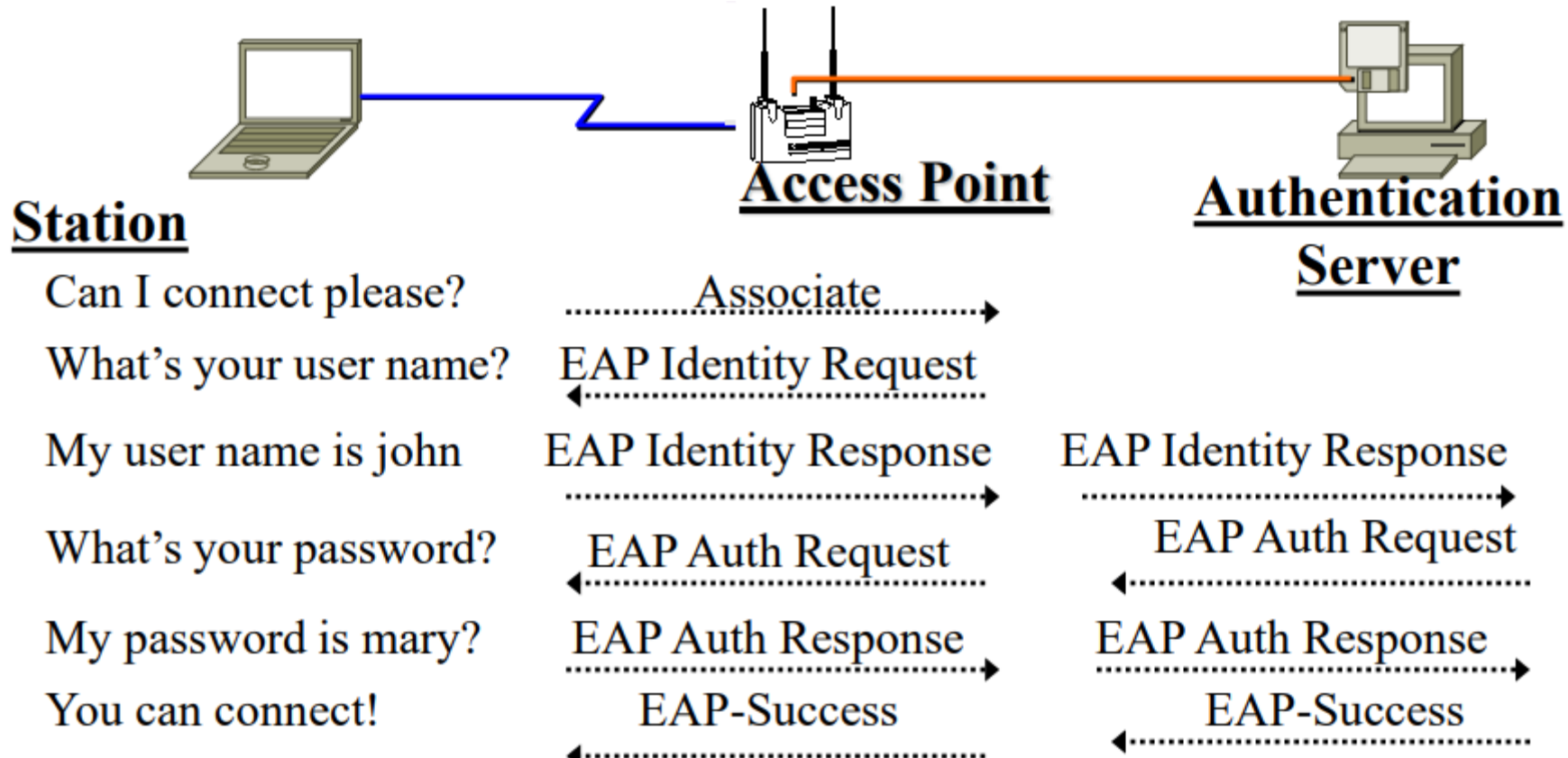
EAPOL Message Format



802.1X Authentication

π

- › Authentication method can be changed without upgrading switches and access points
- › Because only the client and authentication server need to implement the authentication method



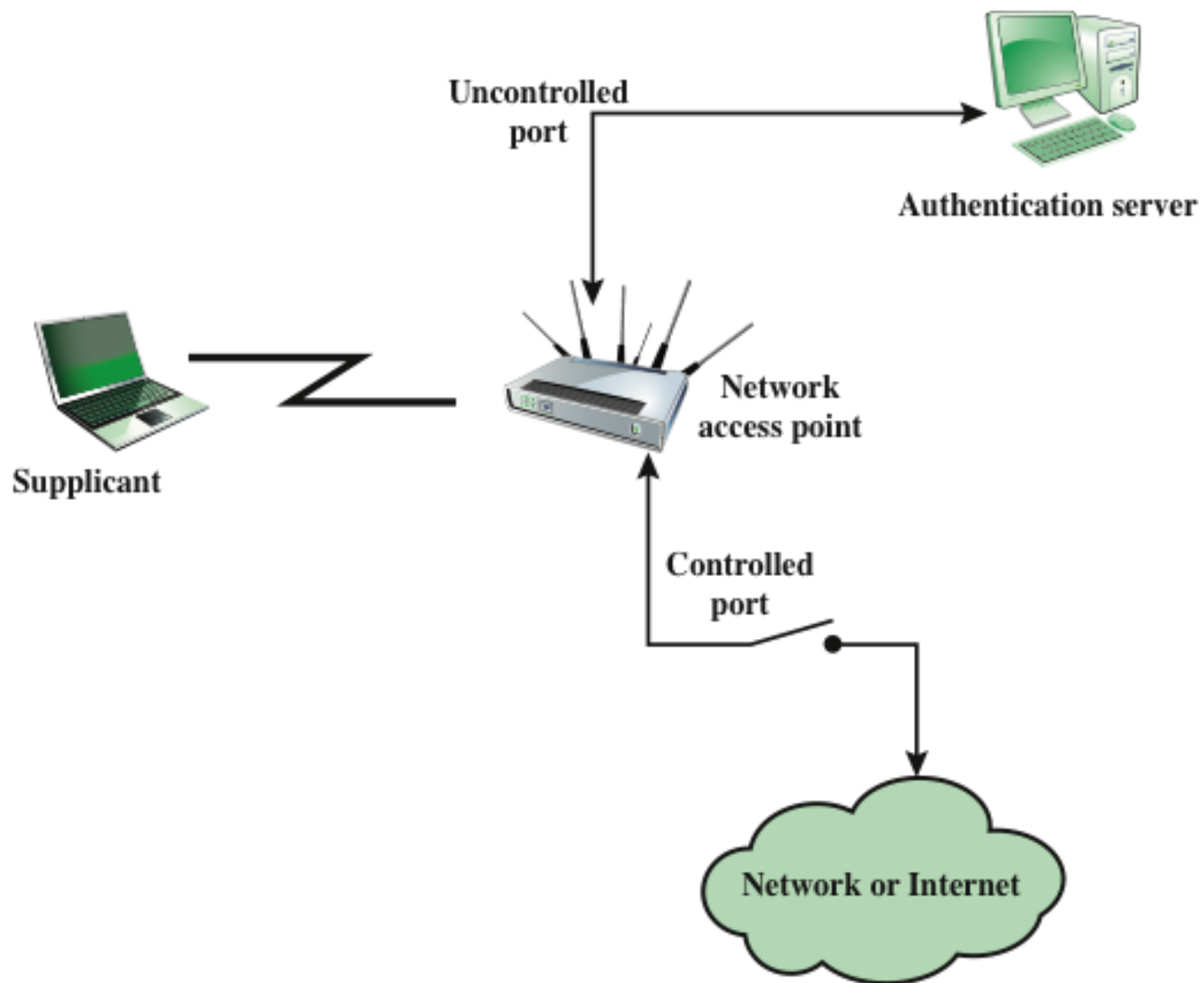


Figure 16.5 802.1X Access Control

Cloud Computing

π

- › Utilize remote resources, i.e. processor, storage, network, software, and services
- › Five Characteristics
 1. Shared: Resource Pooling
 2. Ubiquitous: Broad network access
 3. Rapidly Provisioned: Rapid Elasticity
 4. Configurable: Measured Service
 5. On-demand Self-Service
- › Three Service Models
 1. Infrastructure as a Service (IaaS): CPU
 2. Platform as a Service (PaaS): CPU+OS
 3. Software as a Service (SaaS): Application
- › Four Deployment Models: Public, Private, Hybrid, and Community

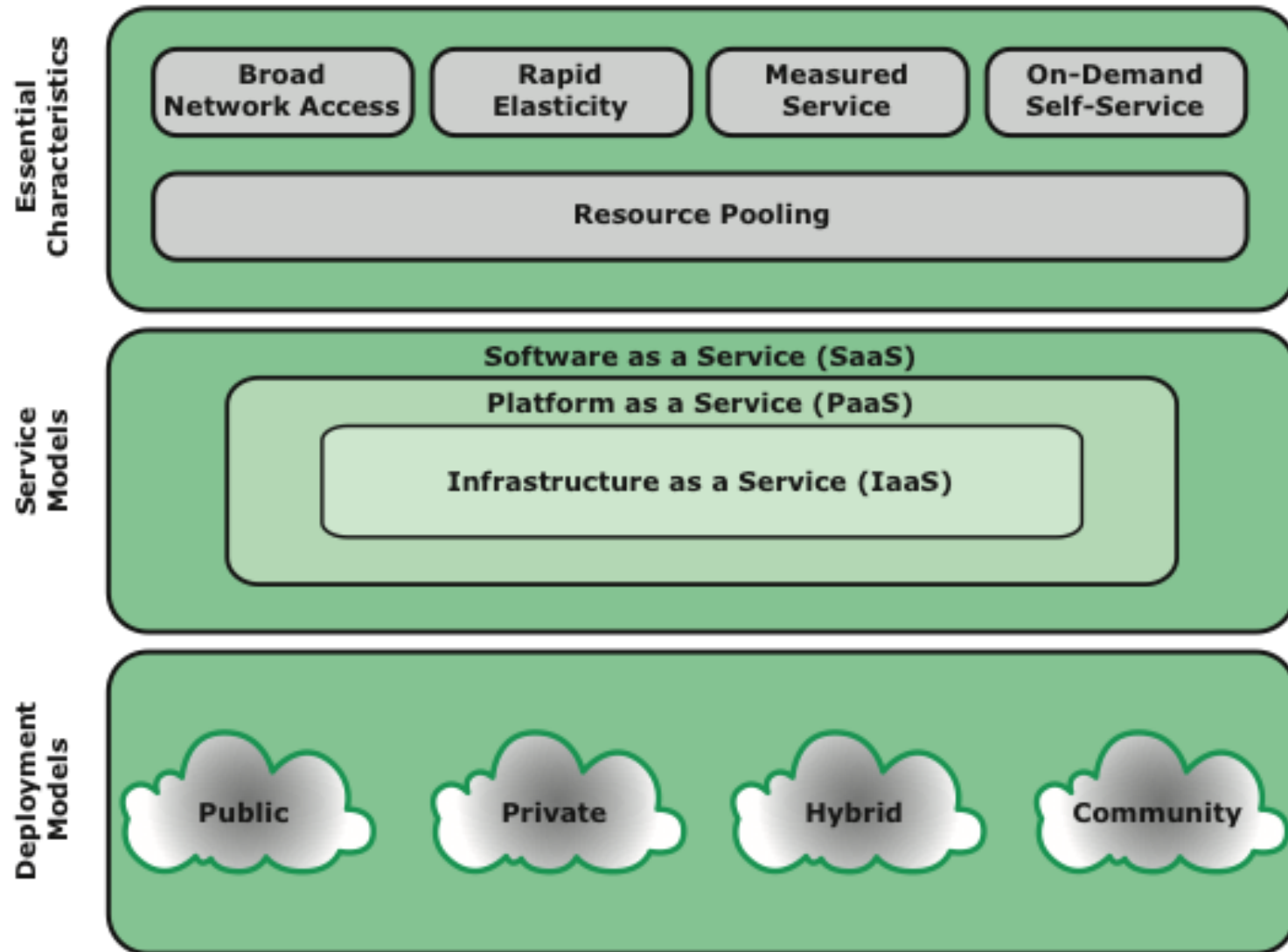


Figure 16.7 Cloud Computing Elements

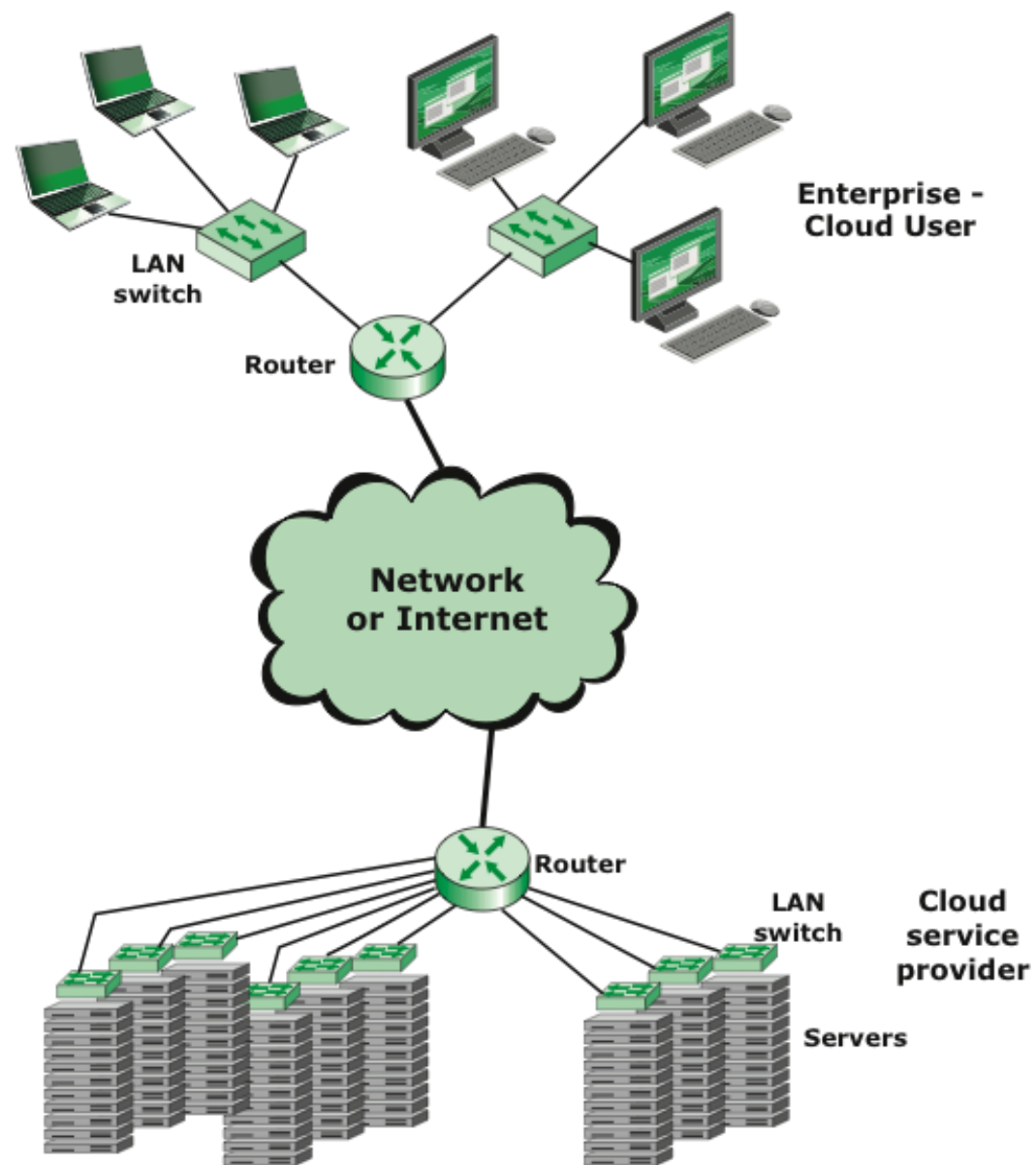


Figure 16.8 Cloud Computing Context

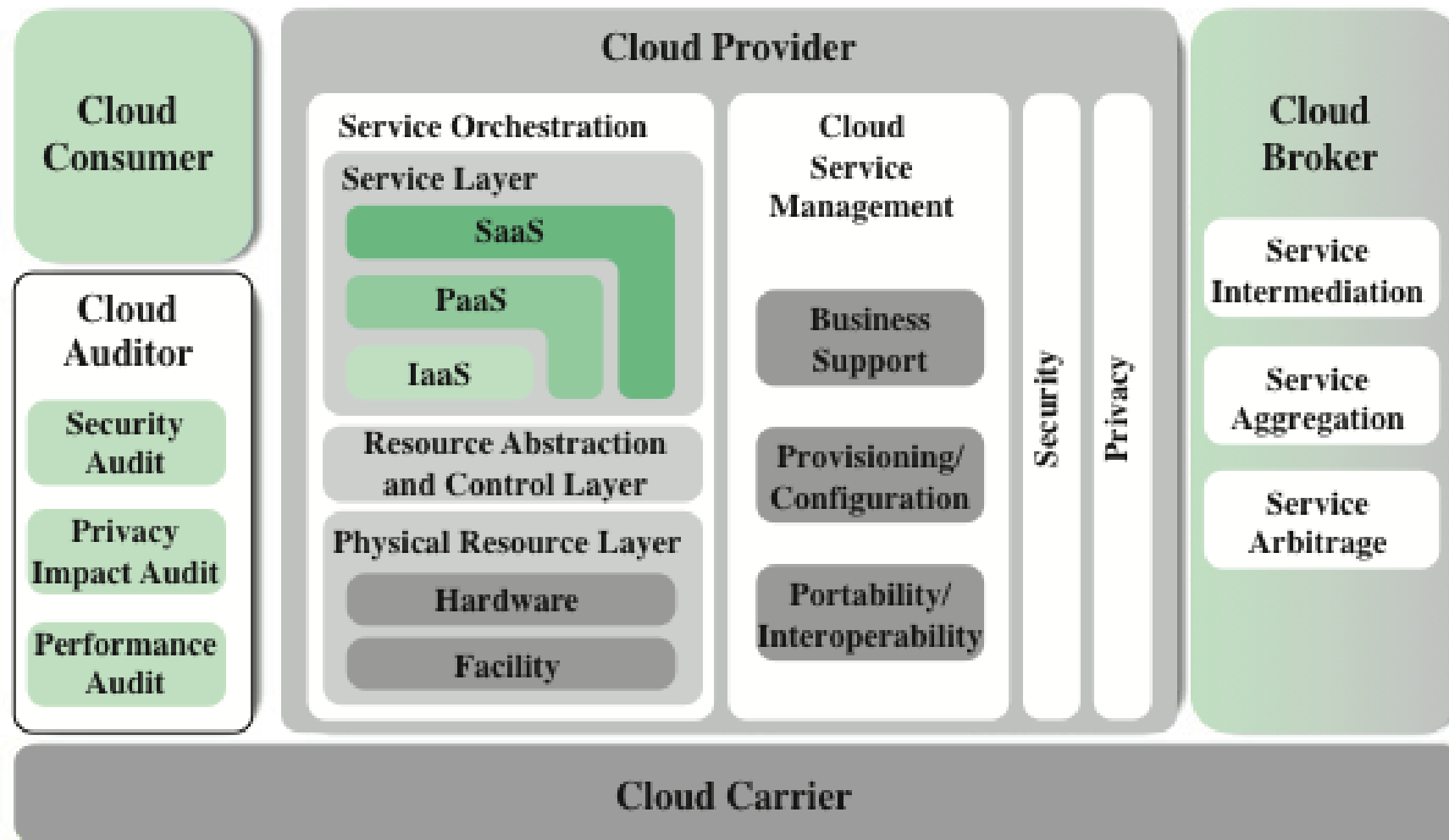
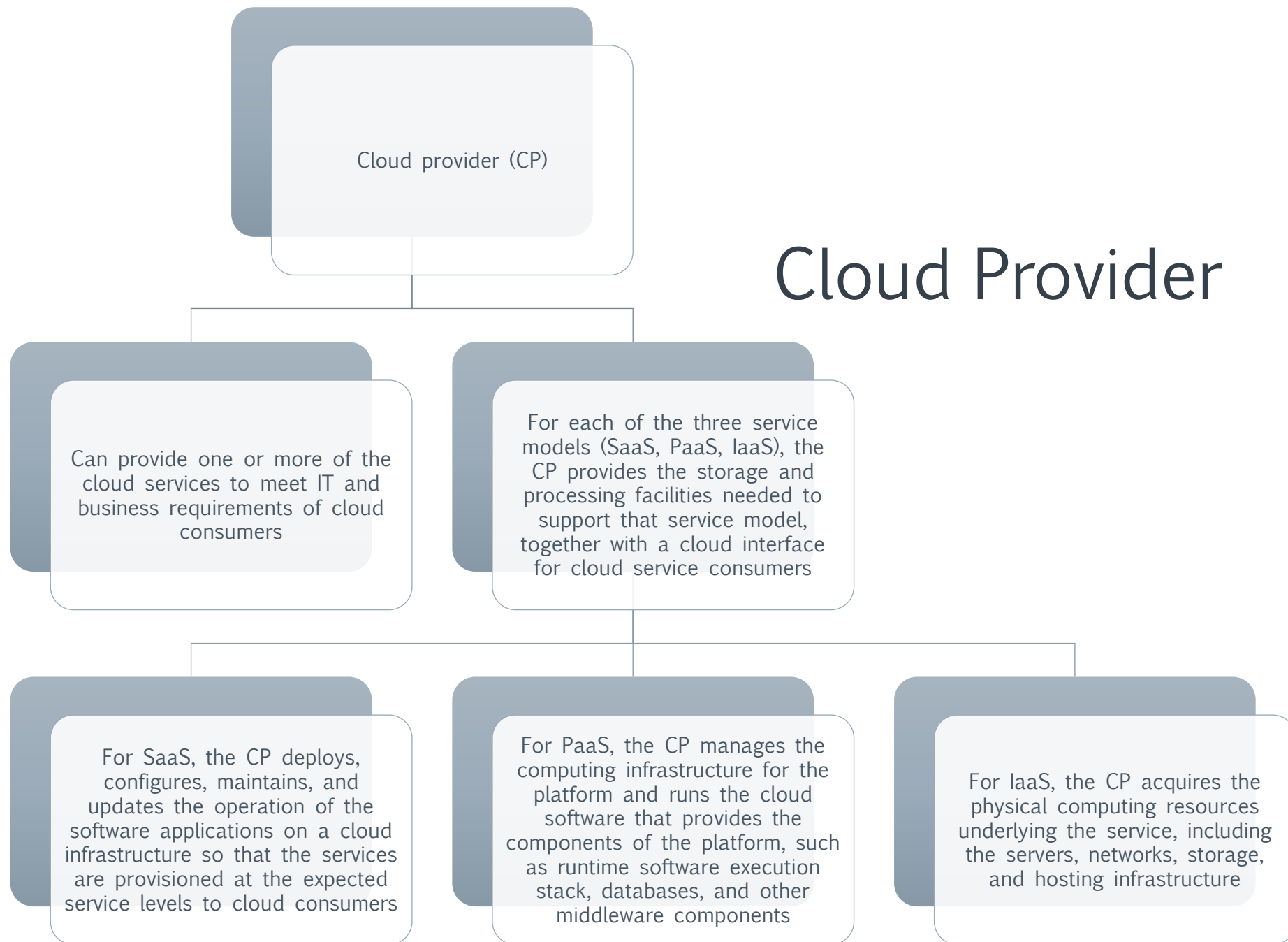


Figure 16.9 NIST Cloud Computing Reference Architecture



Roles and Responsibilities

Cloud carrier

- A networking facility that provides connectivity and transport of cloud services between cloud consumers and CPs

Cloud auditor

- An independent entity that can assure that the CP conforms to a set of standards

Cloud broker

- Useful when cloud services are too complex for a cloud consumer to easily manage
- Three areas of support can be offered by a cloud broker:
 - Service intermediation
 - Value-added services such as identity management, performance reporting, and enhanced security
 - Service aggregation
 - The broker combines multiple cloud services to meet consumer needs not specifically addressed by a single CP, or to optimize performance or minimize cost
 - Service arbitrage
 - A broker has the flexibility to choose services from

Cloud 7 Security Risks and Countermeasures

1. Abuse and Criminal Use:

- Strict user authentication
- Intrusion detection
- Monitoring public blacklists for own network blocks

2. Malicious Insiders:

- Comprehensive assessment of CSP
- Human resource requirement as a part of the legal contract
- Transparency into overall security management
- Security breach notification process

3. Insecure Interfaces and API's:

- Analyze security models of CSP interface
- Ensure strong authentication and encryption

Cloud 7 Security Risks and Countermeasures

4. Shared Technology Issues:

- Monitor environment for unauthorized changes
- Strong authentication and access control for administrators
- SLAs for patching vulnerability remediation
- Conduct vulnerability scanning and configuration audits

5. Data Loss or Leakage:

- Strong API access control
- Encrypt data in transit
- Analyze data protection at design and runtime
- Strong key generation, storage, management, and destructions

Cloud 7 Security Risks and Countermeasures

6. Account or Service Hijacking:

- No sharing of credentials between users and services
- Strong two-factor authentication
- Intrusion detection
- Understand CSP security policies and SLAs

7. Unknown Risk Profile:

- Disclosure of applicable logs and data
- Partial/full disclosure of infrastructure details
- Monitoring and alerting on necessary information

NIST 9 Guidelines on Cloud Security

1. Governance:

- Extend organizational policies and procedures to cloud
- Audit mechanisms to ensure that policies are followed

2. Compliance:

- Understand legal and regulatory obligations
- Ensure that the contract meets these obligations
- Ensure that CSP's discovery capabilities do not compromise security and privacy of data

3. Trust:

- Clear exclusive ownership of data
- Institute a risk management system
- Visibility into the security and privacy controls of CSP
- Constant system monitoring

NIST 9 Guidelines on Cloud Security

4. Architecture:

- Understand CSP's provisioning methods and their impact on the security over the entire life cycle

5. Identity and Access Management:

- Strong authentication, authorization, and identity management

6. Software Isolation:

- Understand the virtualization techniques and their risks

7. Data Protection:

- Evaluate CSP's ability to control access to data at rest, in transit, and in use and to sanitize data
- Assess risk of collating data with other organizations with high threat value
- Understand CSP's cryptographic key management

NIST 9 Guidelines on Cloud Security

8. Availability:

- Assess procedures for data backup, recovery, and disaster recovery
- Ensure critical operations can be resumed immediately after a disaster. Other operations can be eventually resumed as well

9. Incident Response:

- Ensure contract provisions for incident response meet your requirements
- Ensure that CSP has a transparent process to share information during and after an incident
- Ensure that you can respond to incident in coordination with CSP

Data Protection in the Cloud

- › The threat of data compromise increases in the cloud
- › Two database service models:
 - Multi-instance model
 - › Provides a unique DBMS running on a virtual machine instance for each cloud subscriber
 - › This gives the subscriber complete control over role definition, user authorization, and other administrative tasks related to security
 - Multi-tenant model
 - › Provides a predefined environment for the cloud subscriber that is shared with other tenants, typically through tagging data with a subscriber identifier
 - › Tagging gives the appearance of exclusive use of the instance, but relies on the CSP to establish and maintain a sound secure database environment

Data Protection in the Cloud

- › Data must be secured while at rest, in transit, and in use, and access to the data must be controlled
- › The client can employ encryption to protect data in transit, though this involves key management responsibilities for the CSP
- › Ideal security measure for the client is to encrypt the database and only store encrypted data in the cloud, with the CSP having no access to the encryption key
- › A straightforward solution to the security problem in this context is to encrypt the entire database and not provide the encryption/decryption keys to the service provider
 - The user has little ability to access individual data items based on searches or indexing on key parameters
 - The user would have to download entire tables from the database, decrypt the tables, and work with the results
 - To provide more flexibility it must be possible to work with the database in its encrypted form

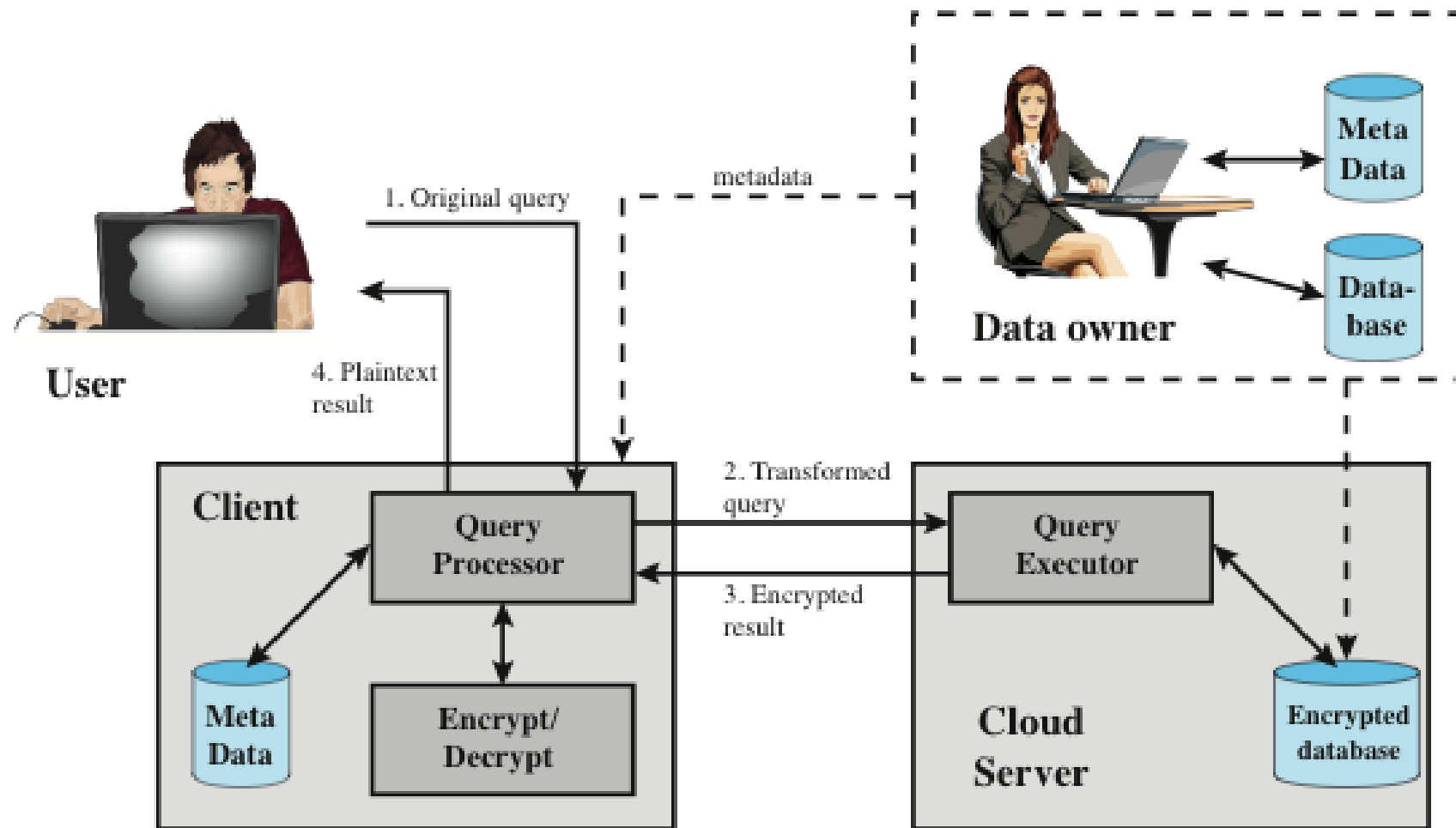


Figure 16.10 An Encryption Scheme for a Cloud-Based Database

Cloud Security as a Service (SecaaS)

- › Provisioning of security applications and services via the cloud either to cloud-based infrastructure and software or from the cloud to the customers' on premise systems
- › The Cloud Security Alliance has identified the following SecaaS categories of service:
 - Identity and access management
 - Data loss prevention
 - Web security
 - E-mail security
 - Security assessments
 - Intrusion management
 - Security information and event management
 - Encryption
 - Business continuity and disaster recovery
 - Network security

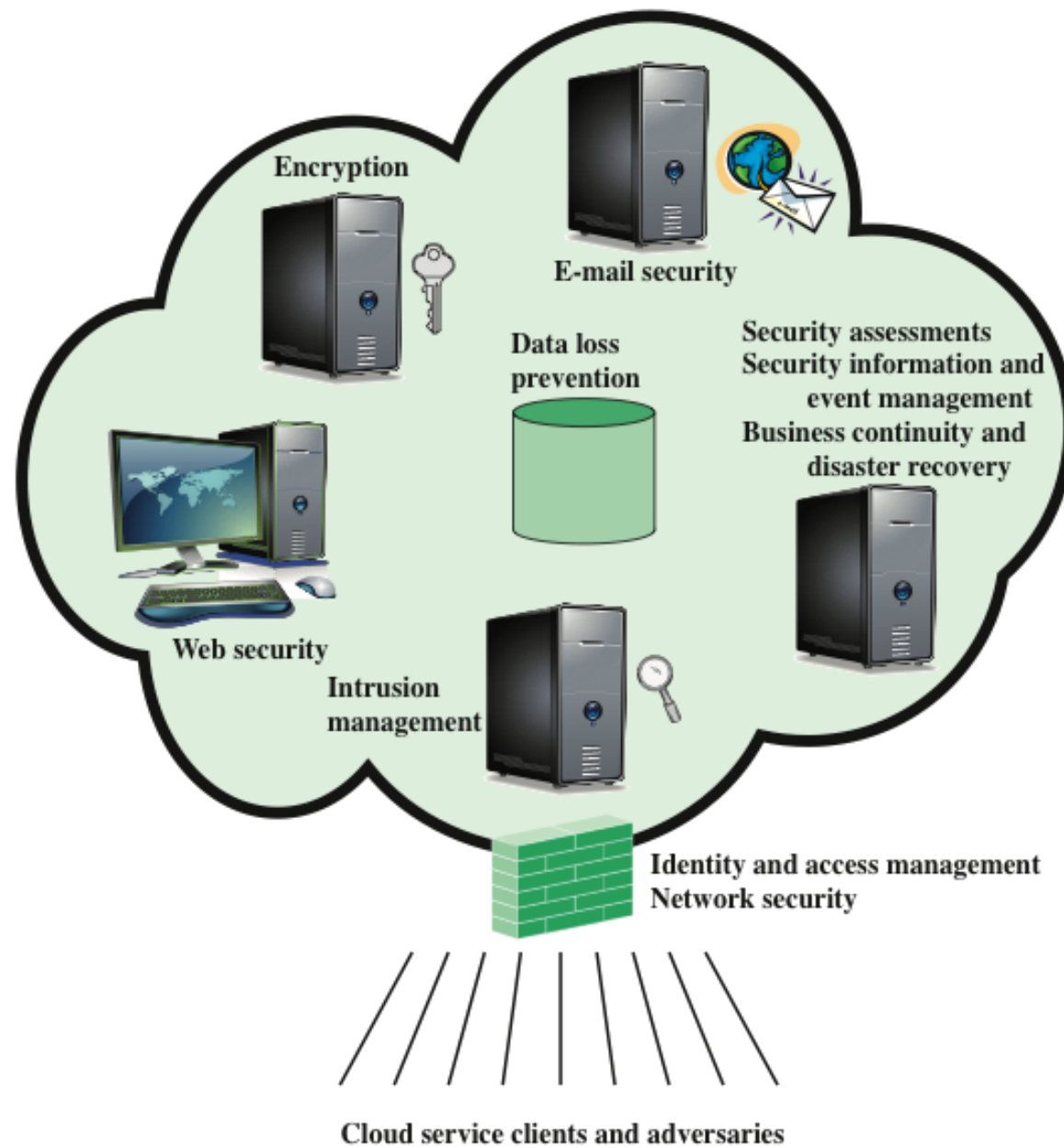


Figure 16.11 Elements of Cloud Security as a Service